

Malware 恶意软件

Learning Objective

- Understand three broad mechanisms malware uses to propagate.
- Learn about the basic operation of viruses, worms, and Trojans.
- Learn about some malware countermeasure elements.

Introduction

Malware

全称: **Malicious software**

Any software intentionally designed to cause damage to a computer, server, client, or computer network.

任何被故意设计用于对计算机、服务器、客户端或计算机网络造成损害的软件。

In the modern threat landscape, understanding the taxonomy of malware is a prerequisite for organizational resilience. Malware is no longer merely "bad code"; it is a strategic tool designed to compromise the **CIA Triad** (Confidentiality, Integrity, and Availability). For the Cybersecurity Architect, viewing malware through a structural lens—focusing on **propagation** and **payload**—is essential for designing a defense-in-depth posture that anticipates blended threats rather than just reacting to isolated incidents.

Core Classification Matrix

To effectively categorize threats and allocate defensive resources, we distinguish malware by its biological-like characteristics:

By Requirement (Host Dependency):

- **Parasitic Code:** Requires a host program or file to function (e.g., traditional viruses).
- **Independent Code:** Self-contained and runs autonomously (e.g., worms).

By Replication:

- **Self-Replicating:** Designed to spread and create copies across systems (e.g., viruses and worms).
- **Non-Replicating:** Does not spread on its own once active (e.g., certain Trojans).

The Propagation-Payload Framework

We separate the "delivery" mechanism from the "objective" to better understand the attacker's intent:

Propagation: How it Spreads	Payload: What it Does
Infected Content: Viruses attaching to host files.	System Corruption: Data destruction or BIOS/file system corruption.
Vulnerability Exploits: Worms scanning for network weaknesses.	Theft of Service: Converting systems into "zombie agents" for botnets.
Social Engineering: Tricking users via Phishing or Trojans.	Information Theft: Deploying Keyloggers, Spyware, or Phishing.
Drive-by-Downloads: Browser exploitation during site visits.	Stealthing: Using Rootkits and Backdoors to ensure persistence.

Strategic Impact: The Blended Malware Challenge

Attackers have shifted from single-vector malware to **blended malware**, which integrates multiple propagation mechanisms and payloads. This evolution significantly increases the difficulty of perimeter defense.

Strategic Advisory: This shift necessitates a move away from legacy signature-based detection toward behavior-centric activity traps, as blended malware can hide its primary payload while spreading through secondary social engineering vectors.

战略建议： 这种转变要求从传统的基于签名的检测转向以行为为中心的活动陷阱， 因为混合型恶意软件能够在通过次要的社会工程向量传播时隐藏其主要有效负载。

Propagation: Infected Content — Viruses

Viruses

A virus is a parasitic entity that relies on host programs and user interaction to achieve its objectives. Once attached to an executable, it inherits the permissions of the host, allowing it to perform any action the user is authorized to execute.

病毒是一种寄生物， 依赖宿主程序和用户交互来实现其目标。一旦附着在可执行文件上， 它便继承了宿主的权限， 从而能够执行用户被授权进行的任何操作。

Virus Components 病毒的三大核心组件

- Infection mechanism
 - Means by which a virus spreads or propagates
 - Also referred to as the infection vector
- Trigger
 - Event or condition that determines when the payload is activated or delivered
 - Sometimes known as a logic bomb
- Payload
 - What the virus does (besides spreading)
 - May involve damage or benign but noticeable activity
- 感染机制 (Infection mechanism): 决定病毒如何传播或感染其他程序的媒介。
- 触发器 (Trigger): 有时被称为“逻辑炸弹 (logic bomb)”， 是指决定病毒的“有效载荷”何时被激活或交付的特定事件或条件。
- 有效载荷 (Payload): 指病毒除了自我传播之外所执行的具体动作， 这些动作可能造成破坏， 也可能只是良性但引人注意的活动。

Virus Four Phases

- Dormant phase
 - Virus is idle
 - Will eventually be activated by some event
 - Not all viruses have this stage
- Propagation phase
 - Virus places a copy of itself into other programs or into certain system areas on the disk
 - May not be identical to the propagating version
 - Each infected program will now contain a clone of the virus which will itself enter a propagation phase
- Triggering phase
 - Virus is activated to perform the function for which it was intended
 - Can be caused by a variety of system events
- Execution phase
 - Function is performed
 - May be harmless or damaging
- **潜伏期 (Dormant phase):** 病毒在此阶段处于闲置状态，等待特定事件将其激活（并非所有病毒都具备此阶段）。
- **传播期 (Propagation phase):** 病毒将自身副本植入其他程序或磁盘的特定系统区域中。需要注意的是，传播的版本不一定与原版完全相同；被感染的程序随后将包含病毒的克隆体，并使其自身也进入传播期。
- **触发期 (Triggering phase):** 可由各种系统事件引起，病毒在此刻被正式激活，准备执行其预设功能。
- **执行期 (Execution phase):** 病毒实际执行其功能的阶段，其产生的影响可能是无害的，也可能是极具破坏性的。

Virus Structure

- **简单病毒的逻辑结构 (Virus structure):** 课件展示了一个标准简单病毒的伪代码逻辑。它首先会不断寻找一个随机的、尚未被感染的程序，并将病毒代码自身附加（prepend）到该目标文件中；一旦触发条件为真（trigger condition is true），它就会执行有效载荷的操作。
- **压缩型病毒结构 (Compression virus):** 课件对比展示了更复杂的压缩型病毒伪代码。在感染目标文件时，它会先将原始的正常文件进行压缩（compress file），然后再将病毒自身附加到压缩文件上。当感染后的程序运行时，它会将原文件解压到临时文件中并予以执行，以确保宿主程序看似仍在正常运行。

Virus Detection

- **基础的病毒的检测:** 针对上述简单的病毒附加行为，课件提出了防范思路，即最基础的检测手段是**基于文件大小的检测 (File-size based detection)**，因为普通病毒附加到宿主文件上必然会导致文件总体积增大。但是这样无法预防第二种压缩型病毒结构，因为文件在被病毒感染之前已经被压缩了。

Virus Classification

- **Classification by target**
 - **Boot Sector:** Infects the Master Boot Record; spreads during disk-based booting.
 - **File Infector:** Targets executable files.
 - **Macro Virus:** Infects application-specific scripting code (e.g., Office docs).
 - **Multipartite Virus:** Employs multiple infection vectors simultaneously.
- **按目标分类 (Classification by target):**
 - **引导扇区感染病毒 (Boot sector infector):** 主要感染系统的主引导记录 (MBR) 或引导记录。当计算机从包含该病

毒的磁盘启动时，病毒就会被激活并传播。

- **文件感染病毒 (File infector)**: 专门针对并感染可执行文件。
- **宏病毒 (Macro virus)**: 感染包含宏或脚本代码的文件，这些代码通常依赖特定的应用程序（如办公软件）来解释和执行。
- **多重感染病毒 (Multipartite virus)**: 一种混合型病毒，能够利用多种不同的方式和途径来感染文件和系统。

- **Classification by concealment strategy**

- **Encrypted**: Uses a random key to hide the virus body.
- **Stealth**: Specifically designed to intercept and falsify AV scanner results.
- **Polymorphic**: Mutates its appearance with every infection.
- **Metamorphic**: The most advanced form; rewrites its own behavior and code structure completely at each iteration.

- **按隐蔽策略分类 (Classification by concealment strategy):**

- **加密病毒 (Encrypted virus)**: 病毒的一部分代码会生成一个随机的加密密钥，并用它来加密病毒的其余部分，以此规避传统的特征码扫描。
- **隐形病毒 (Stealth virus)**: 一种经过专门设计的病毒形式，其明确目的是向防病毒软件隐藏自身的存在，从而逃避安全检测。
- **多态病毒 (Polymorphic virus)**: 在每一次感染新的目标文件时，都会发生变异（改变其代码的外观形态）的病毒。
- **变形病毒 (Metamorphic virus)**: 在每次迭代和传播时不仅会变异，还会**完全重写自身**。这种病毒不仅可能改变外观，甚至可能改变其行为模式，是极难被检测出来的类型。

Safe demo

为了让学生直观理解病毒的三大生命周期组件，课件提供了一个名为 `L8 virus demo.py` 的 Python 脚本，以安全无害的方式演示了病毒的运作逻辑。

- **演示环境设置 (Setup)**: 需要创建一个名为 `L8 virus demo` 的测试文件夹，在其内部建立5个子文件夹（`folder1` 到 `folder5`），并将 Python 脚本保存在主目录下运行。
- **核心组件与代码功能映射 (Component Functions)**:
 - **感染机制 (Infection Mechanism)**: 通过 `infect_directories()` 函数实现。它的行为是将病毒文件自身复制到当前目录下的每一个子文件夹中，模拟病毒的横向传播。
 - **触发器 (Trigger)**: 通过 `check_trigger()` 函数实现。它会检查是否满足预设的激活条件，例如：检查当前日期是否为4月1日、检查是否存在名为 `trigger_me.txt` 的文件，或者检查已被感染的文件夹数量是否 ≥ 3 。
 - **有效载荷 (Payload)**: 通过 `payload()` 函数实现。由于这是一个安全演示，它的有效载荷不包含破坏性行为，仅仅是在目录中创建一个名为 `PAYLOAD_TRIGGERED.txt` 的标记文件，用来向用户证明病毒逻辑已被成功激活。

Propagation: Vulnerability Exploit — Worms 蠕虫

Worms

- A standalone malware computer program that replicates itself in order to spread to other computers.
- Making use of software vulnerabilities
- Can use network connections to spread from system to system
- Spreads through shared media (USB drives, CD, DVD data disks)
- E-mail worms spread in macro or script code included in attachments
- Upon activation the worm may replicate and propagate again
- **独立性与自驱动性**: 与需要寄生在正常宿主程序中的传统病毒不同，蠕虫是一种**独立的恶意计算机程序**，它的核心行为特征

是为了扩散到其他计算机而进行**自我复制**。

- **攻击向量：漏洞利用**：蠕虫主要通过利用软件系统或网络中的**安全漏洞（Vulnerability Exploit）**来寻找突破口。
- **多元化的传播途径**：
 - **网络传播**：蠕虫最典型的特征是能够利用网络连接，直接从一个系统穿透并蔓延到另一个系统。
 - **物理媒介**：它们也可以通过**共享媒介**（例如USB闪存盘、CD和DVD数据盘）进行线下物理扩散。
 - **邮件传播**：作为电子邮件蠕虫（E-mail worms），它们常将自身隐藏在邮件附件的**宏指令或脚本代码**中。一旦用户触发，蠕虫被激活，便会再次启动复制和传播周期。

Worm Propagation

- Search for appropriate access mechanisms to other systems to infect.
- Use the access mechanisms found to transfer a copy of itself to the remote system, and cause the copy to be run.

蠕虫之所以能造成快速且大范围的破坏，主要归功于其全自动的传播阶段。该阶段通常执行以下两个关键功能：

- **主动扫描与探测**：蠕虫会不断在网络中**搜索进入其他系统的适当访问机制**，寻找可供感染的新目标。
- **自动传输与执行**：一旦找到可利用的访问路径（如某个未修复的网络漏洞），它会立刻将**自身的副本传输到远程系统**，并设法强制该副本在远程机器上自动运行。

Worm of Virus

虽然在日常交流中，“病毒”和“蠕虫”这两个术语经常被互换使用，但它们在运行机制上存在本质的区别：

- **是否依赖宿主与人工干预**：**病毒（Viruses）**高度依赖于宿主文件，并且它们的触发通常需要用户的特定操作（例如双击运行被感染的程序或打开受感染的文档）；相对而言，**蠕虫（Worms）**是完全独立、具备自我复制能力的，能够横跨整个网络进行“自动化、无人值守”的自主传播。
- **不要过度纠结分类**：课件特别指出，在现代网络安全环境中“**不要过于纠结分类（Don't obsess about classifications）**”。因为早期的恶意软件通常只使用单一的传播或破坏手段，但现代恶意软件已经进化为**混合型恶意软件（Blended malware）**，它们往往同时融合了病毒的隐蔽性、蠕虫的传播力以及多种有效载荷。
- Terms often used interchangeably
- Viruses are dependent on host files and user actions for replication, while worms are self-replicating and can spread autonomously across networks.
- Don't obsess about classifications

Drive-by-downloads 网络挂马

这是一种极为隐蔽且防不胜防的感染策略，将用户的日常浏览行为变为了攻击触发器：

- **零点击感染**：当用户仅仅是查看了一个由攻击者控制的恶意网页时，攻击就会发生。它通过利用浏览器自身的漏洞，在用户毫不知情（无需点击下载按钮或同意安装）的情况下，将恶意软件强制下载并安装到系统中。
- **被动的传播特性**：与蠕虫满网络主动寻找目标的行为不同，偷渡式下载**通常不具备主动传播的能力**。它采用的是一种“守株待兔”的策略——**只有当受害者主动访问包含恶意代码的特定网页时，这种恶意软件才会发生扩散。**
- Exploits browser vulnerabilities to download and install malware on the system when the user views a Web page controlled by the attacker
- In most cases does not actively propagate
- Spreads when users visit the malicious Web page

Propagation: Social Engineering —Spam E-Mail, Trojans

Social Engineering

- “Tricking” users to assist in the compromise of their own systems
 - Spam / phishing e-mails
 - Unsolicited bulk e-mail
 - Significant carrier of malware
 - Used for phishing attacks
 - Trojan horse
 - Seemingly useful program that contains code that does harmful things
 - Mobile phone Trojans
 - First appeared in 2004 (Skuller)
 - Target is the smartphone

1. 传播的核心机制：社会工程学 (Social Engineering)

与蠕虫直接利用系统漏洞不同，社会工程学攻击不完全依赖技术手段，而是通过“**欺骗 (Tricking)**”**用户的信任**，诱导受害者在不知情的情况下主动协助攻击者，从而妥协并感染自身的系统。

2. 垃圾邮件与网络钓鱼 (Spam / Phishing e-mails)

- **垃圾邮件特征**：指未经用户请求而批量发送的电子邮件（Unsolicited bulk e-mail）。它们在网络中泛滥，是投递恶意软件的重要载体。
- **网络钓鱼**：攻击者经常利用垃圾邮件发起钓鱼攻击。课件图片中展示了一个典型的钓鱼邮件案例：攻击者伪装成西交利物浦大学 (XJTLU) 的系统管理员，以“邮箱账号升级/迁移”为借口，诱导教职工点击恶意链接。
- **识别技巧**：课件通过该案例指出了识别钓鱼邮件的关键线索——**检查发件人的实际域名**。例如，一封自称来自大学官方的邮件，其发件人地址却使用了第三方的公共域名（如 `@gmail.com`），这通常是判断其为恶意邮件的第一个明显标志。

特洛伊木马 (Trojans)

传统木马 (Trojan horse)：木马利用的是伪装策略。它表面上看起来是一个有用且合法的程序（例如某个实用工具或游戏），但其内部却暗藏着执行破坏性操作的恶意代码。用户通常因为其极具迷惑性的外表而主动下载并运行。

手机木马 (Mobile phone Trojans)：随着移动设备的普及，智能手机也成为了木马的重要攻击目标。课件中特别补充了一个历史知识点：**历史上第一个针对手机的木马程序名为“Skuller”，首次出现于 2004 年。**

Payload

System corruption

- Data Destruction
 - Chernobyl virus
 - First seen in 1998
 - Windows 95 and 98 virus
 - Infects executable files and corrupts the entire file system when a trigger date is reached
 - Klez
 - Computer worm that propagates via e-mail
 - First appeared in 2001
 - On trigger date causes files on the hard drive to become empty
 - Ransomware
 - Encrypts the user's data and demands payment in order to access the key needed to recover the

information

- Recent ransomware demands the victim pay in Bitcoin.
- Logical Bomb
 - Code embedded in the malware that is set to “explode” when certain conditions are met

这类有效载荷旨在直接破坏系统数据或造成现实世界的影响。课件列举了以下几种典型手段：

知名破坏性病毒案例：

- **切尔诺贝利病毒 (Chernobyl virus)**：首现于1998年，针对Win95/98系统。当到达特定触发日期时，它不仅会破坏整个文件系统，还会重写主板的BIOS代码，造成硬件级别的现实破坏。
- **Klez（求职信）蠕虫**：2001年出现的邮件蠕虫，在触发日会导致硬盘上的文件被清空。
- **勒索软件 (Ransomware)**：恶意加密用户的数据，并要求受害者支付赎金（近年来通常要求支付比特币）以换取解密密钥。
- **逻辑炸弹 (Logic bomb)**：一种嵌入在恶意软件中的代码，当满足预设的特定条件时就会“引爆”执行破坏。触发条件可能包括：特定文件或设备的存在与否、一周中的某天或特定日期、特定版本的软件配置，甚至特定用户的登录。

Attack Agent

- Takes over another Internet attached computer and uses that computer to launch or manage attacks
- Botnet - collection of bots capable of acting in a coordinated manner

恶意软件将受感染的计算机转化为攻击者的“傀儡（Zombie）”或“机器人（Bot）”。

- **僵尸网络 (Botnet)**：攻击者接管大量连接互联网的计算机，将它们组成一个能够协同行动的僵尸网络。
- **主要用途**：这些被控制的计算机将被用来发起分布式拒绝服务（DDoS）攻击、发送海量垃圾邮件、嗅探网络流量，或作为跳板去传播新的恶意软件。

Information theft

- Keyloggers
 - Captures keystrokes to allow attacker to monitor sensitive information
 - Typically uses some form of filtering mechanism that only returns information close to keywords (“login”, “password”)
- Spyware
 - Subverts the compromised machine to allow monitoring of a wide range of activity on the system
 - Monitoring history and content of browsing activity
 - Redirecting certain Web page requests to fake sites
 - Dynamically modifying data exchanged between the browser and certain Web sites of interest
- Phishing:
 - Exploits social engineering to leverage the user’s trust by masquerading as communication from a trusted source

这类有效载荷隐蔽地窃取受害者的隐私与敏感数据：

- **键盘记录器 (Keyloggers)**：暗中捕获用户的键盘输入以监控敏感信息。为了提高效率，它们通常使用过滤机制，只回传与特定关键词（如“login/登录”、“password/密码”）相关的上下文输入。
- **间谍软件 (Spyware)**：控制受感染机器以广泛监控系统活动。它可以监控浏览历史和内容、将特定的网页请求重定向到假冒网站，甚至动态修改浏览器与特定目标网站之间交换的数据。
- **网络钓鱼 (Phishing)**：结合社会工程学伪装成受信任的来源。典型手法是在垃圾邮件中包含一个伪造的URL，链接到模仿银

行、游戏等网站的假登录页面，以此骗取并捕获用户的账户凭据。

Stealthing 隐蔽技术

- Backdoor
 - Also known as a trapdoor
 - Secret entry point into a program allowing the attacker to gain access and bypass the security access procedures
 - Maintenance hook is a backdoor used by Programmers to debug and test programs
- Malware that has taken over a machine often inserts a trapdoor
 - To allow the attacker to get back in
 - Infected machine should be handled carefully to remove such trapdoors
- Rootkit
 - Software designed to maintain illicit access to a computer
 - Installed after attacker has gained very privileged access on the system
 - Goal is to ensure continued privileged access
 - By hiding presence of malware
 - By defending against removal

为了长期潜伏并维持对系统的控制，恶意软件会利用隐蔽手段对抗安全软件的清理：

- **后门/陷门 (Backdoors / Trapdoors)**：这是程序中的秘密入口，允许攻击者绕过正常的安全访问程序直接进入系统。后门原本可能是程序员为了调试方便而留下的“维护钩子 (Maintenance hook)”，但恶意软件在接管机器后通常也会植入自己的后门，以便日后重返系统。
- **Rootkit (提权隐蔽工具)**：这是一种旨在维持计算机非法访问权限的软件。攻击者通常在获得系统最高特权（Root/管理员权限）后安装它。Rootkit 的核心目标是通过**隐藏恶意软件的踪迹并防御杀毒软件的清除**，来确保攻击者能够长久地保持特权访问。

Countermeasures 反制手段

Malware countermeasure approaches

- Prevention
 - Policy
 - Ensure all systems are as current as possible
 - Reduce vulnerabilities
 - Set appropriate access controls on the applications and data
 - Provide appropriate user awareness and training
- Threat mitigation options:
 - Detection
 - Identification
 - Removal

应对恶意软件的整体策略应当多管齐下，建立多重防线。课件将其划分为以下几个核心阶段和措施：

- **预防 (Prevention)**：这是最基础也是最关键的一环。具体建议包括：制定规范的安全策略 (Policy)。确保所有系统和软件都尽可能保持最新状态（及时更新和打补丁）。主动减少系统中的脆弱点和漏洞 (Reduce vulnerabilities)。对应用程序和重要数据实施适当的**访问控制 (Access controls)**。为用户提供必要的安全意识培训，减少因社会工程学导致的感染。

- **响应与处置流程**：安全系统需要具备**检测 (Detection)**威胁、**识别 (Identification)** 清除 (**Removal**) 的能力。
- **事后缓解与恢复**：在遭受攻击且无法完全拦截时，应启动**威胁缓解 (Mitigation)** 选项，并依靠系统**备份 (Backup)** 来挽回数据损失

Generations of anti-virus

- First generation: simple scanners
 - Requires a malware signature to identify the malware
 - Another approach is length checking
- Second generation: heuristic scanners
 - Uses heuristic rules to search for probable malware instances
 - Another approach is integrity checking
- Third generation: activity traps
 - Identify malware by its actions rather than its structure in an infected program
- Fourth generation: full-featured protection
 - Packages consisting of a variety of anti-virus techniques used in conjunction

为了对抗不断进化的隐蔽技术和变种恶意软件，杀毒软件经历了四个世代的技术升级：

- **第一代：简单扫描器 (Simple scanners)**
 - **核心机制**：强依赖于**特征库匹配**，即需要已知恶意软件的**特征码 (Malware signature)** 才能将其识别。
 - **补充手段**：使用**文件长度检查 (Length checking)**，这种方法特别针对那些简单将自身附加到宿主文件上导致文件体积变大的基础病毒。
- **第二代：启发式扫描器 (Heuristic scanners)**
 - **核心机制**：变得更加智能，使用**启发式规则 (Heuristic rules)** 来搜索可能是恶意软件的代码片段或指令序列，能够抓出未被记录在特征库中的未知变种。
 - **补充手段**：引入了**完整性检查 (Integrity checking)**，监控文件是否遭到非法篡改。
- **第三代：活动陷阱 (Activity traps)**
 - **核心机制**：检测逻辑从“静态看代码”转向了“动态看行为”。它通过监控程序运行时的**实际动作 (Actions)** 来判定其是否恶意，彻底摆脱了对受感染程序内部结构的依赖。
- **第四代：全功能防护 (Full-featured protection)**
 - **核心机制**：代表了当今主流的综合安全软件形态。它不再是单一的工具，而是将**多种不同世代的防病毒技术整合在一起协同工作**的防护套件 (Packages)，提供全方位的防御网络。